

Atelier 4 détaillé et Registre de risques dans CISO Assistant

Quatre scénarios ont été cotés sur une matrice et leur traitement décidé. Ces décisions vivent encore sur le brouillon, ce qui veut dire qu'elles n'existent pas : un risque qui n'est pas dans le registre est un risque que personne ne suivra. Ce TP fait entrer ce travail dans l'outil du groupe, et l'entrée n'est pas une saisie. La reprise de l'atelier 4 en détail fera découvrir que l'outil pose des questions que le brouillon n'avait pas posées.

Objectifs de la séance

À l'issue de ce TP, l'instance du groupe de travail contient :

- Les **scénarios opérationnels** de l'atelier 4 déclinés à partir des chemins d'attaque de la séance 6, chacun rattaché à son scénario stratégique
- Une **estimation de vraisemblance** par scénario opérationnel, justifiée par les biens supports traversés et non par une impression globale
- Un **registre de risques** où chaque scénario porte sa cotation actuelle, son option de traitement et son responsable
- Un **risque résiduel** coté pour chaque scénario traité, cohérent avec le niveau actuel
- Une **note d'écart** listant ce que l'outil a fait découvrir et que le brouillon ne contenait pas

Prérequis

- Le dossier D5 de la séance 5 : cadrage, échelles justifiées, socle, valeurs métier et biens supports repris de la séance 2, couples source de risque et objectif visé.
- Les scénarios stratégiques de la séance 6 et leurs chemins d'attaque, notamment ceux qui passent par les tiers critiques de la filiale instruite (§3 et §6 du dossier de filiale).
- Les cotations et décisions du TD de ce matin.
- Un accès à l'instance du groupe de travail, avec l'étude ouverte en séance 5 et enrichie en séance 6. **Rien ne se recrée.** Si un objet manque, il se retrouve là où il a été créé.

Ce que l'atelier 4 ajoute, et pourquoi il ne se fait pas de tête

Le cours a défini le scénario opérationnel comme un enchaînement d'actions élémentaires portées sur les biens supports, estimé en vraisemblance, et la séance 6 a posé la règle qui relie les deux ateliers : à chaque chemin d'attaque retenu à l'atelier 3 correspond un scénario opérationnel. Reste à comprendre pourquoi cet atelier mérite une séquence entière alors qu'il semble n'être qu'une mise au propre.

La raison tient à la nature de l'exercice. Un scénario stratégique dit par où l'attaque passe, en nommant l'écosystème ; il tient en une phrase et se discute en comité. Un scénario opérationnel dit comment elle se fait, bien support par bien support, et cette descente change la conversation. C'est en écrivant l'enchaînement que l'on découvre le maillon dont personne n'avait parlé : le compte de service qu'aucune procédure ne révoque, le flux d'administration qui contourne le cloisonnement, la sauvegarde accessible depuis le même réseau que ce qu'elle sauvegarde. Le scénario stratégique se raisonne, le scénario opérationnel se constate.

Scénario stratégique

dit par où l'attaque passe, en nommant l'écosystème
tient en une phrase, se discute en comité

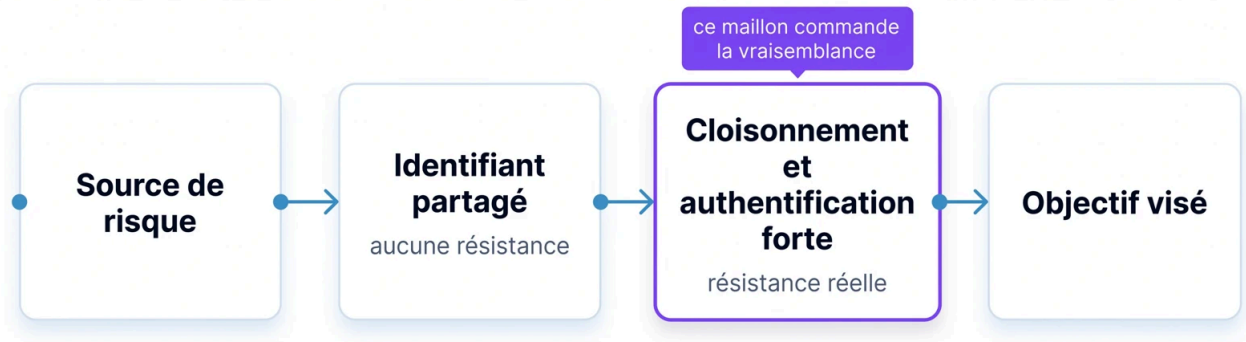
se décline

Scénario opérationnel

dit comment elle se fait, bien support par bien support
se constate en écrivant l'enchaînement des actions

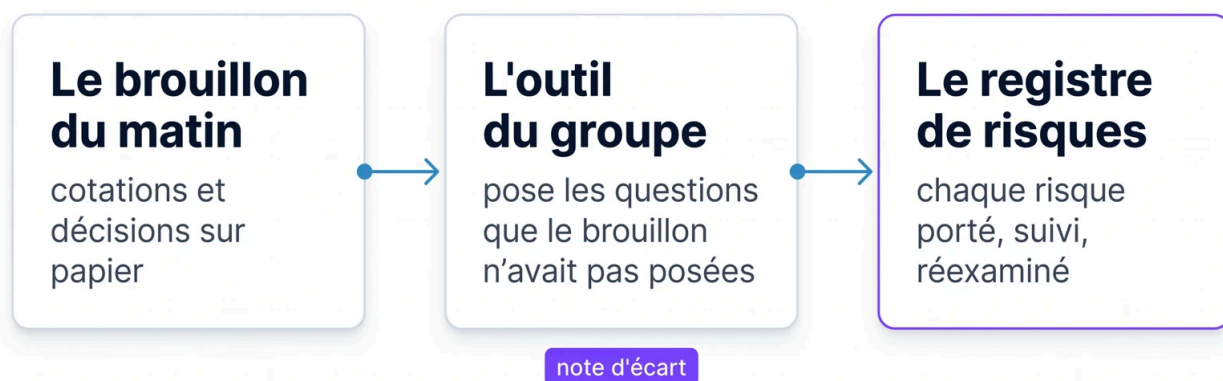
De cette différence découle la règle de cotation de la vraisemblance, qui est la difficulté du jour. La vraisemblance d'un scénario opérationnel ne s'estime pas globalement, au jugé ; elle s'estime à partir du chemin réellement parcouru et de ce que chaque étape exige de l'attaquant. Une étape qui ne demande qu'un identifiant partagé et connu de plusieurs personnes n'oppose aucune résistance. Une étape qui suppose de franchir un cloisonnement

effectif, avec authentification forte et journalisation, en oppose une réelle. La question à se poser à chaque maillon est toujours la même : qu'est-ce qui, ici, arrêterait quelqu'un ?



Un dernier point de méthode avant de commencer. Ce TP est écrit en objectifs et en critères de validation, pas en suite de clics. La révision de l'outil déployée peut différer de celle sur laquelle ces objets ont été vérifiés, et un intitulé d'écran change plus vite qu'une méthode. Si un libellé cherché porte un autre nom, chercher la fonction correspondante et noter l'écart : cette note fait partie du livrable.

Étape 1 : décliner les chemins d'attaque en scénarios opérationnels (25 minutes)



Consignes

Décliner chaque scénario stratégique retenu en séance 6 en un scénario opérationnel, enregistré dans l'outil à l'atelier 4 et rattaché à son chemin d'attaque ; au minimum les deux qui passent par les parties prenantes critiques. Le scénario s'écrit comme un enchaînement d'actions élémentaires, connaître, rentrer, trouver, exploiter, où chaque étape nomme un bien support de l'inventaire de la séance 2 et l'action portée sur lui, et dit ce qui s'y oppose aujourd'hui : mesure du socle, cloisonnement, authentification, journalisation, ou rien. Un bien support absent de l'inventaire est un trou de cartographie à noter, pas un objet à inventer.

À produire : au moins deux scénarios opérationnels enregistrés dans l'outil, rattachés à leur chemin d'attaque, chaque étape nommant un bien support et ce qui s'y oppose ; les biens supports manquants notés pour la note d'écart.

Critères de validation

Le scénario opérationnel est complet quand un collègue qui ne connaît pas le dossier peut lire l'enchaînement et dire à quel endroit il faudrait agir. S'il ne peut pas, c'est que les biens supports manquent ou que les étapes sont formulées en intentions plutôt qu'en actions.

✓ Étape 2 : estimer la vraisemblance, maillon par maillon (20 minutes)

Consignes

Estimer la vraisemblance de chaque scénario opérationnel, de V1 à V4, avec l'échelle du D5 telle quelle, et la saisir dans l'outil avec sa justification. La vraisemblance se lit sur le chemin réellement parcouru : l'étape qui oppose le plus de résistance commande la note de l'ensemble. La justification nomme ses appuis, un écart de l'audit de la séance 4, une pratique observée, la maturité et la confiance cotées à l'atelier 3 pour la partie prenante traversée, un incident public au mode opératoire comparable ; pas une impression, et pas la gravité de ce qui arriverait. Pour le scénario déjà coté au TD, vérifier que le niveau affiché correspond à la matrice.

À produire : une vraisemblance par scénario opérationnel, saisie dans l'outil, avec une justification qui cite au moins un signal vérifiable et la cotation de la partie prenante traversée.

Le piège de cette étape

La tentation sera de coter au vu du résultat, c'est-à-dire de partir de la gravité de ce qui arriverait. Y résister : les deux axes sont séparés depuis ce matin pour cette raison précise. Un scénario catastrophique et très difficile à réaliser existe, et il se cote comme tel.

Critères de validation

Chaque vraisemblance renvoie à un niveau nommé de l'échelle et cite au moins un signal vérifiable. Une justification qui ne contient que des adjectifs n'est pas une justification.

✓ Étape 3 : constituer le registre de risques (25 minutes)

Consignes

Générer l'analyse de risques depuis l'étude, atelier 5, activité 1 : c'est le registre du périmètre, créé une seule fois, avec un scénario de risque par scénario opérationnel, auxquels l'outil ajoute les événements redoutés sans scénario, à coter à leur tour au regard du socle constaté en séance 4. Pour chaque scénario, arrêter l'option de traitement parmi les statuts de l'outil ; un scénario laissé ouvert en fin de séance porte au minimum l'explication

écrite de son report et le nom de qui décidera. Chaque réduction porte ses mesures appliquées, leur porteur pris dans la carte du pouvoir du dossier de filiale (§3) et leur échéance ; chaque acceptation, sa motivation, son échéance de réexamen et l'instance qui la signera. Le contrôle qualité de l'outil passé au vert fait partie du livrable.

À produire : le registre généré et complet, tous les scénarios cotés, chacun avec sa décision ou la justification de son report, les réductions avec mesures, porteur et échéance, les acceptations avec motivation, réexamen et instance.

Critères de validation

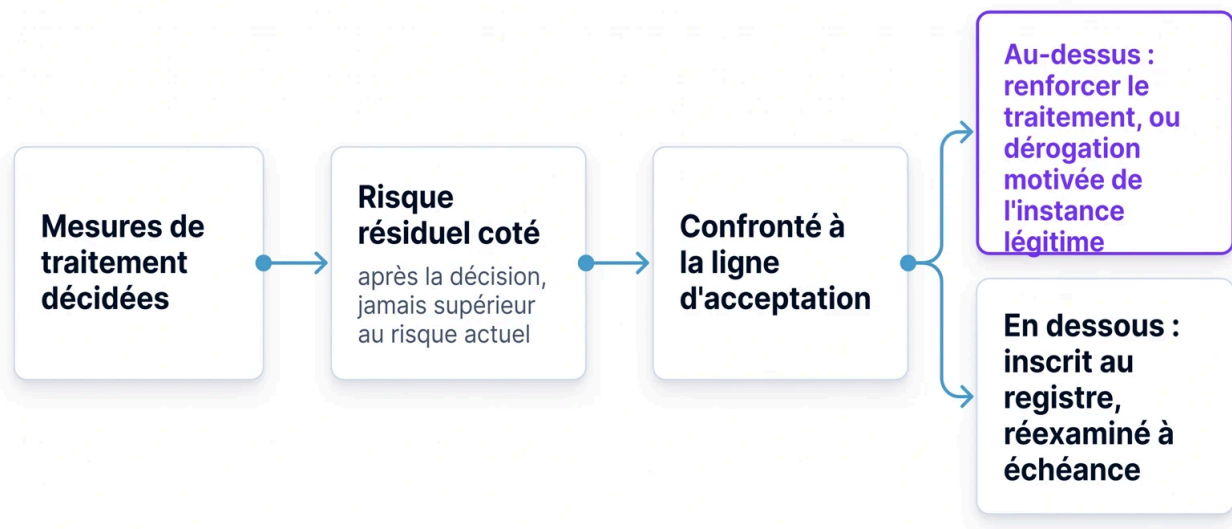
Aucun scénario n'est laissé sans décision ni sans justification de l'absence de décision. Chaque réduction porte un nom de responsable et une date. Chaque acceptation porte sa motivation et sa date de réexamen.

✓ Étape 4 : coter le risque résiduel (20 minutes)

Consignes

Coter le risque résiduel de chaque scénario traité, après la décision et jamais avant, en se demandant ce que les mesures changent réellement : une résistance ajoutée sur le chemin abaisse la vraisemblance, une réduction de ce qui serait atteint abaisse la gravité, rarement les deux. L'outil refuse un résiduel supérieur au niveau actuel et rappelle qu'un scénario sans mesure supplémentaire garde le même niveau : ces refus font partie de la méthode. Confronter ensuite chaque résiduel à la ligne d'acceptation : s'il reste au-dessus, renforcer le traitement ou préparer la demande d'acceptation dérogatoire pour l'instance légitime ; les deux issues se préparent dans la séquence suivante.

À produire : un résiduel coté par scénario traité, cohérent avec le niveau actuel, et la liste des résiduels qui restent au-dessus de la ligne d'acceptation, avec l'issue choisie pour chacun.



Ce que le refus de l'outil enseigne

Un outil qui refuse une saisie n'est pas un outil pénible, c'est une règle de méthode rendue impossible à contourner. Qu'un traitement ne puisse pas aggraver le risque qu'il traite paraît évident écrit ainsi ; dans un tableur, cette incohérence passe inaperçue des mois durant. Qui pense qu'une mesure crée un risque nouveau a raison de le penser et se trompe d'endroit : ce risque nouveau est un scénario distinct, qui se cote pour lui-même.

✓ Grille d'auto-évaluation

Critère	Atteint quand	Signe que ce n'est pas atteint
Continuité avec la séance 6	Chaque scénario opérationnel se rattache à un chemin d'attaque existant	Des scénarios créés de zéro dans l'outil
Ancrage dans la cartographie	Chaque étape nomme un bien support de l'inventaire	Des étapes en termes génériques, sans objet nommé
Échelles reprises	Les niveaux cités sont ceux du D5, mot pour mot	Une échelle réinventée ou des libellés modifiés
Justification des vraisemblances	Chaque note cite un signal vérifiable	Des adjectifs sans source
Complétude du registre	Aucun scénario sans décision, aucune mesure sans porteur	Des scénarios laissés en état ouvert sans explication
Cohérence du résiduel	Coté après décision, jamais supérieur à l'actuel	Un résiduel saisi avant les mesures
Honnêteté de la note d'écart	Les libellés d'écran divergents et les biens supports manquants sont notés	Une note d'écart vide alors que des objets manquaient

✓ Ce que ce TP transmet à la suite

L'étude porte désormais un registre complet : des scénarios opérationnels ancrés dans les biens supports, des vraisemblances justifiées, des décisions avec leurs porteurs, et des résiduels cohérents. La dernière séquence de la journée en tire le plan de traitement et le dossier D7, et la note de stratégie gagne sa sous-section de traitement du risque.

Garder la note d'écart sous la main : ce que l'outil a fait découvrir et que le brouillon ne contenait pas est souvent le passage le plus convaincant d'une soutenance. Un candidat qui montre ce que la méthode lui a appris est plus crédible qu'un candidat dont le dossier semble n'avoir jamais rencontré de surprise.



Corrigé enseignant : le TP joué sur TRAMONTANE (instance GØ)

— cliquer pour révéler